Segurança de Rede em Nuvem

Conceitos e Práticas de Redes Cloud — Aula 9

Prof. Alexandre da Costa Tavares Junior



Agenda

- Recapitulação: Balanceamento de Carga e CDN
- Modelo de Responsabilidade Compartilhada
- Defesa em Profundidade
- IAM e Menor Privilégio
- Criptografia (trânsito e repouso)
- Web Application Firewall (WAF)
- Proteção contra DDoS
- Conectividade Segura (VPN, PrivateLink)
- Monitoramento e Detecção de Ameaças
- Resumo e Próxima Aula



Recapitulação

> **Aula anterior — Balanceamento de Carga e CDN:**
> ALB (L7), NLB (L4), GWLB (L3)
> Health Checks e algoritmos de distribuição
> CDN: edge locations, cache hit/miss, TTL
> Arquitetura integrada CDN + LB

Conexão com hoje: LB e CDN entregam performance — agora vamos PROTEGER toda essa infraestrutura com segurança em múltiplas camadas.



Responsabilidade Compartilhada

🏢 Provedor (DA nuvem)

- Hardware / Datacenter
- Rede física global
- Hipervisor
- Segurança física

👤 Cliente (NA nuvem)

- Dados e criptografia
- IAM / Acessos
- Config de rede (SG, NACL)
- Aplicação / Patching

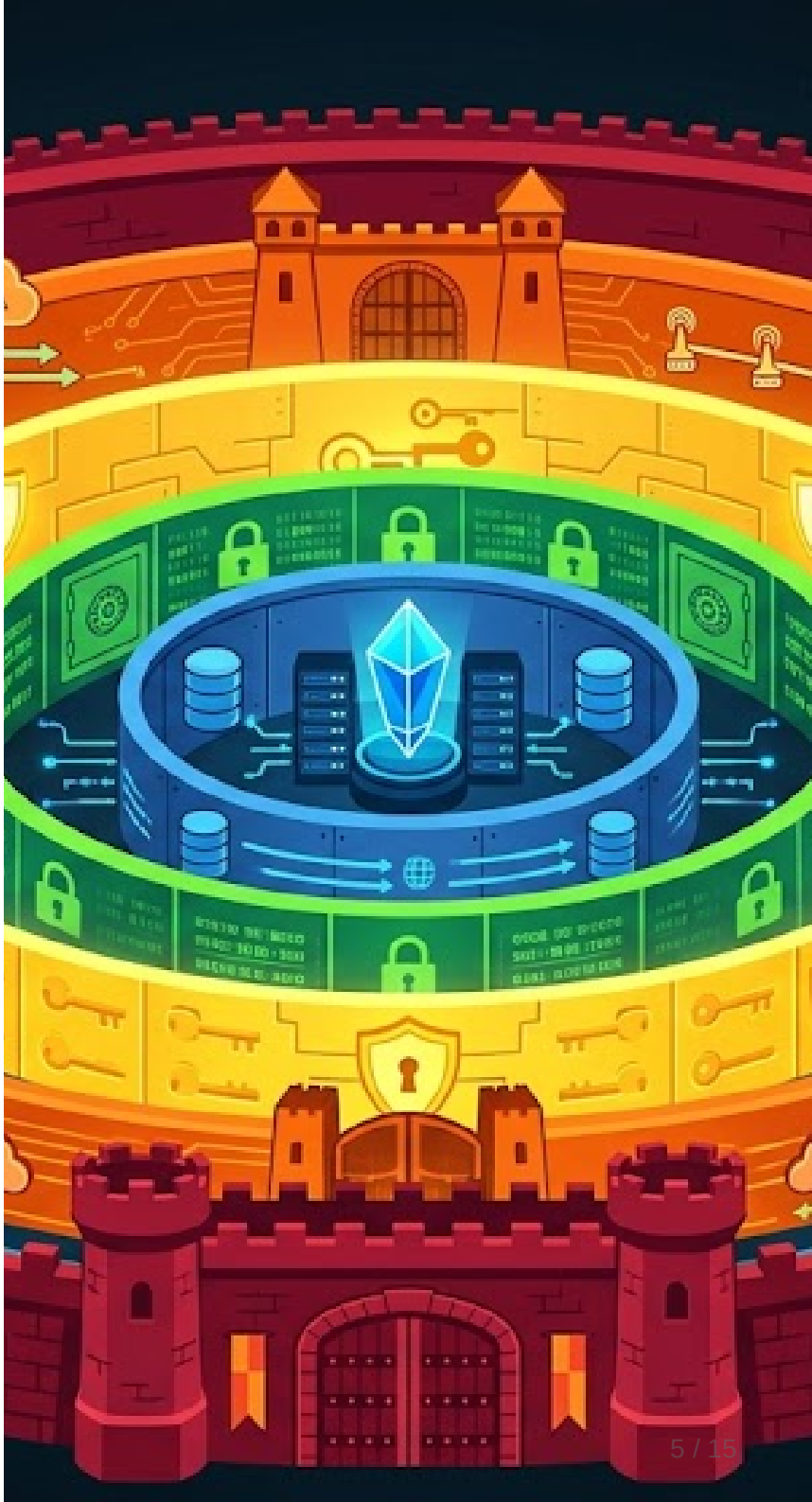
⚠️ **Fato:** > 95% dos incidentes em nuvem são causados por erro de configuração do CLIENTE.



Defesa em Profundidade

```
┌──────────────────────────────────┐
│ BORDA: CDN + Shield + WAF        │  Camada 1
├──────────────────────────────────┤
│ REDE: VPC + SG + NACLs           │  Camada 2
├──────────────────────────────────┤
│ COMPUTE: Patching + IMDSv2       │  Camada 3
├──────────────────────────────────┤
│ APP: Auth + Input Validation     │  Camada 4
├──────────────────────────────────┤
│ DADOS: Criptografia + Backup     │  Camada 5
└──────────────────────────────────┘
```

Princípio: Se uma camada falha, as próximas mantêm a proteção.



IAM: Controle de Acesso

Componente	Descrição
👤 User	Identidade humana com credenciais
👥 Group	Coleção de usuários
🎭 Role	Identidade temporária (assumível)
📄 Policy	Documento JSON de permissões
🔐 MFA	Segundo fator obrigatório

> **Menor Privilégio:** Comece com ZERO permissões. Adicione apenas o estritamente necessário. Revise periodicamente.



Criptografia

🔒 Em Trânsito

- TLS 1.2/1.3 (HTTPS)
- Terminação no LB
- mTLS (autenticação mútua)
- IPsec (VPN)

🗄️ Em Repouso

- AES-256 (disco/storage)
- KMS (gerenciamento de chaves)
- Rotação automática
- CloudHSM (FIPS 140-2)

> **Regra de ouro:** Criptografe TUDO — em trânsito e em repouso. Sem exceções.



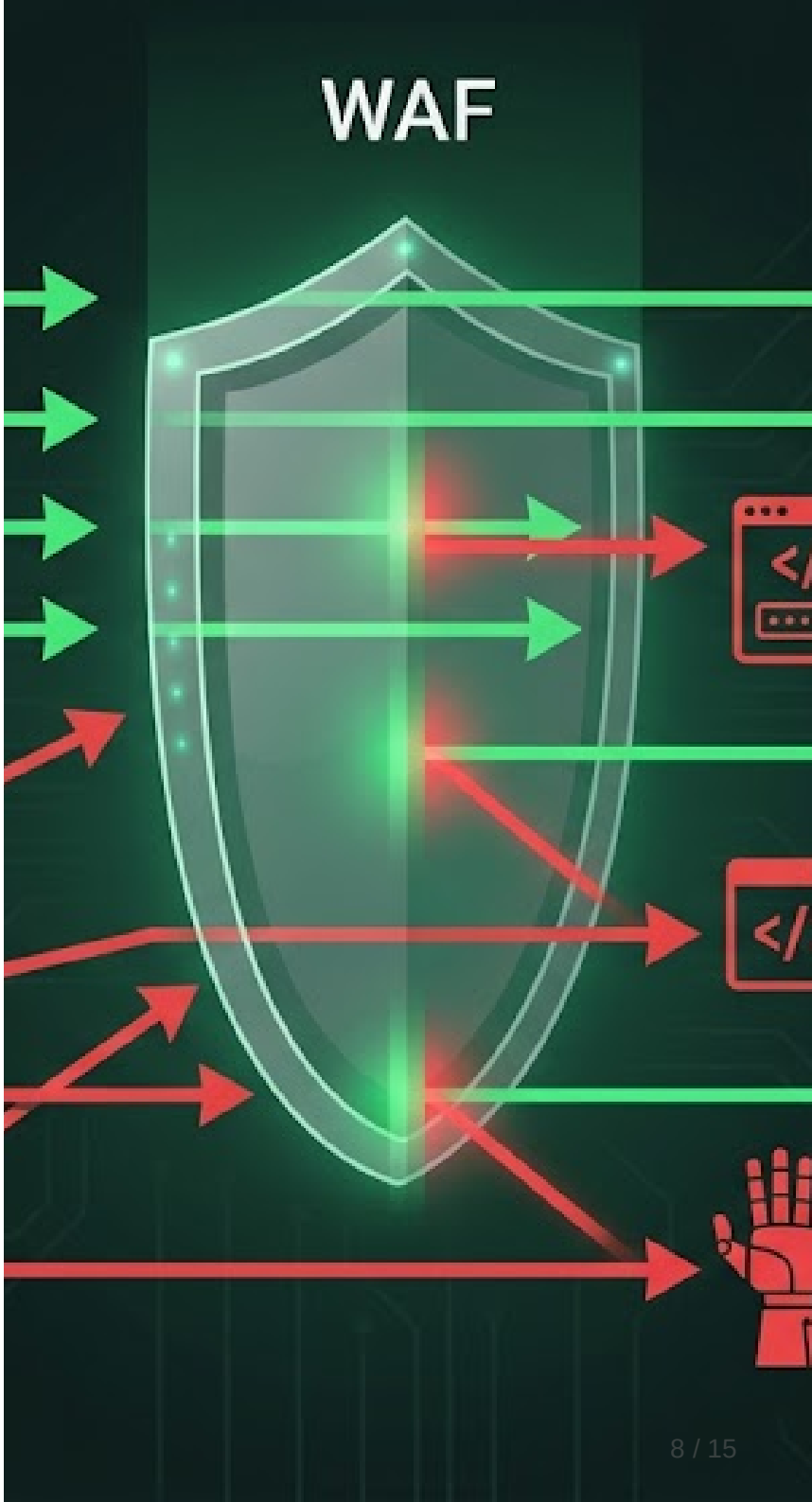
WAF (Web Application Firewall)

Posicionamento: Na borda, antes da aplicação (ALB ou CloudFront)

Ataques bloqueados:

- 💉 SQL Injection
- 📝 Cross-Site Scripting (XSS)
- 🗂️ Path Traversal
- 🤖 Bots maliciosos
- 🚫 Brute force (rate limiting)

Tipo de Regra	Manutenção
Managed Rules (OWASP Top 10)	Automática
Custom Rules	Manual
Rate-based Rules	Automática



Proteção contra DDoS

```
Ataque DDoS (volume massivo)
    ↓
CDN (absorve tráfego distribuído)
    ↓
Shield (detecta padrões anormais)
    ↓
WAF (filtra camada 7)
    ↓
✅ Apenas tráfego legítimo
```

Serviço	Proteção	Custo
Shield Standard	L3/L4 automática	Gratuito
Shield Advanced	L3/4/7 + DRT	~$3K/mês
Azure DDoS Protection	L3/4/7	Variável



Conectividade Segura

🔗 VPN Site-to-Site

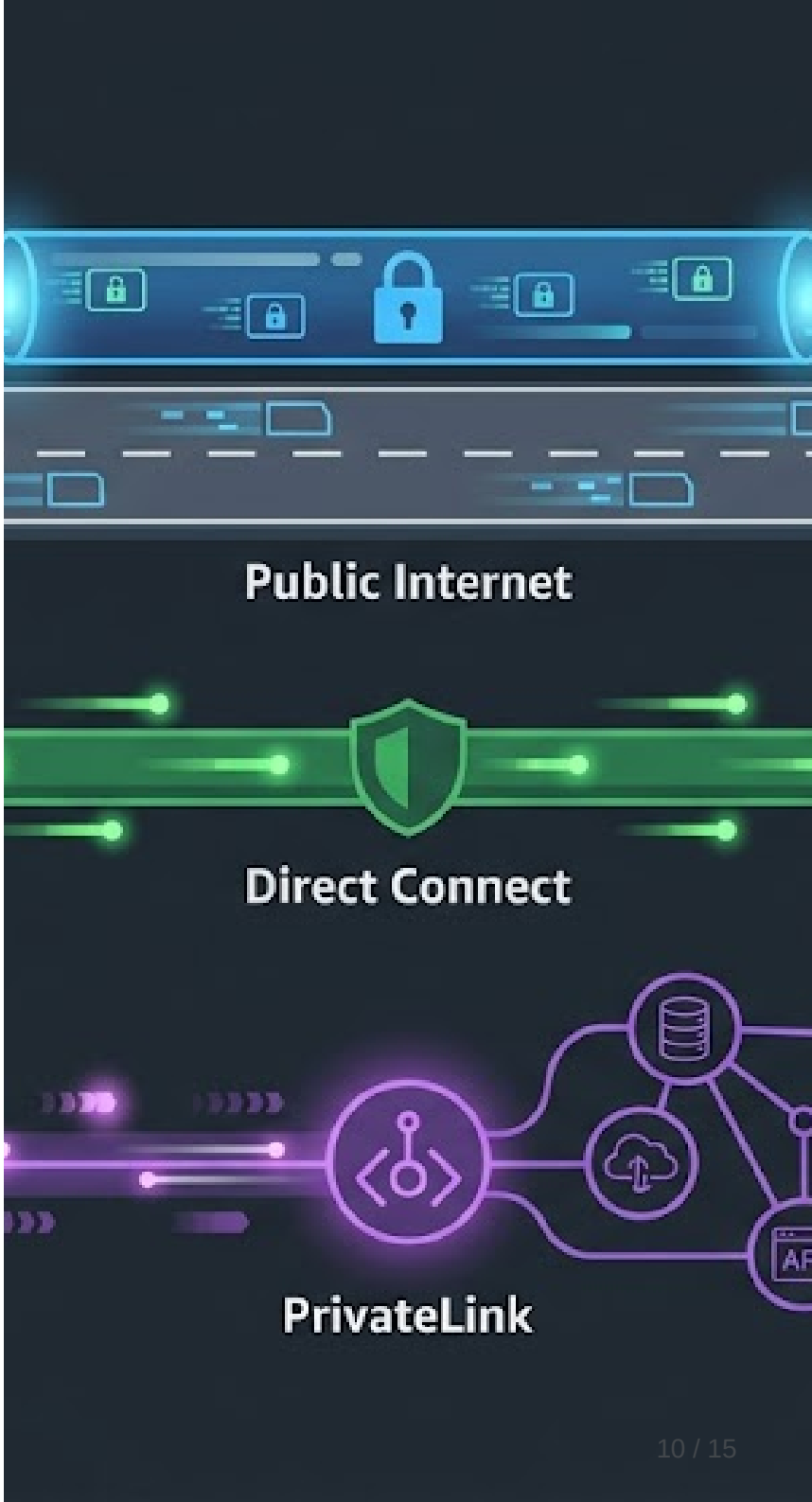
- Túnel IPsec (AES-256)
- Via internet pública
- Até 1,25 Gbps/túnel
- Custo moderado

⚡ Direct Connect

- Fibra dedicada
- Não usa internet
- 1/10/100 Gbps
- Latência consistente

🔒 VPC Endpoints (PrivateLink)

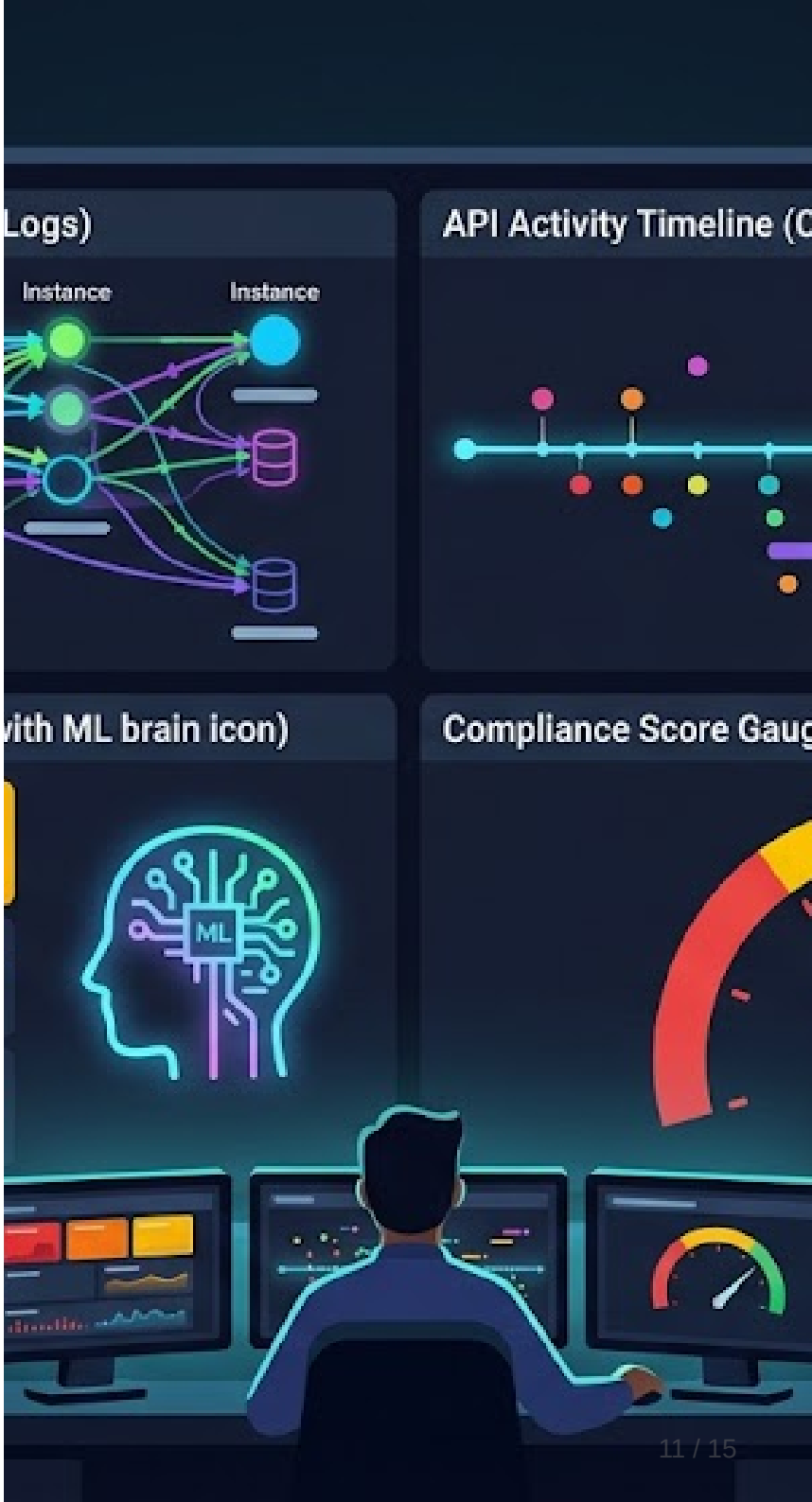
Acesso privado a serviços AWS sem internet. Tráfego permanece interno. Elimina NAT Gateway para esses serviços.



Monitoramento e Detecção

Ferramenta	Monitora	Uso
VPC Flow Logs	Tráfego de rede	Análise de anomalias
CloudTrail	Chamadas de API	Auditoria/compliance
GuardDuty	Ameaças (ML)	Detecção automática
Security Hub	Findings agregados	Visão centralizada
Inspector	Vulnerabilidades	Patching proativo

> **Segurança = Prevenção + Detecção + Resposta**



Top 10 Boas Práticas

1. 🔐 MFA em TODAS as contas (especialmente root)
2. 🎯 Menor privilégio em IAM
3. 🔒 Criptografia em trânsito e repouso
4. 🛡️ Security Groups restritivos
5. 📊 Flow Logs + CloudTrail SEMPRE ativos
6. 🤖 GuardDuty habilitado
7. 🚫 Zero SSH/RDP aberto ao mundo
8. 🔑 Rotação automática de credenciais
9. 🏗️ VPC Endpoints para serviços AWS
10. 📋 Revisão periódica de permissões



Resumo

Conceitos-chave desta aula:

- Responsabilidade Compartilhada: cliente configura, provedor protege infra
- Defesa em Profundidade: múltiplas camadas independentes
- IAM + Menor Privilégio: controle granular de acesso
- Criptografia: trânsito (TLS) + repouso (KMS)
- WAF: proteção L7 (SQLi, XSS)
- Shield: proteção DDoS automática
- Monitoramento: Flow Logs, CloudTrail, GuardDuty

Próxima aula: Monitoramento, Logging e Observabilidade em Nuvem



Referências

- AMAZON WEB SERVICES. *AWS Security Best Practices*. AWS Documentation, 2024.
- AMAZON WEB SERVICES. *Shared Responsibility Model*. AWS Documentation, 2024.
- GARTNER. *Cloud Security Hype Cycle*. Gartner Research, 2023.
- STALLINGS, W. *Network Security Essentials*. 7. ed. Pearson, 2022.
- VERAS, M. *Cloud Computing*. 2. ed. Brasport, 2019.



Atividade

📝 Tarefa Formativa (TF)

Responda às 8 questões objetivas sobre Segurança de Rede em Nuvem.

💭 Para reflexão

Analise esta política IAM:

```
"Effect": "Allow", "Action": "s3:*", "Resource": "*"
```

Quais riscos ela apresenta? Como reescrevê-la com menor privilégio para um serviço que só precisa LER objetos de UM bucket específico?

